

Vulnerability Assessment Report

Internship: Sumerix Global Cybersecurity & Ethical Hacking Internship
Task 3: Vulnerability Scanning & Assessment

Submitted By: Aditya Narke
Domain: Cybersecurity & Ethical Hacking
Internship Program: Sumerix Global Virtual Internship
Department: Computer Science Engineering
Date: June 2026

Table of Contents

Sr No	Section Name	Page Number
1	Executive Summary	3
2	Introduction	3
3	Assessment Objectives	3
4	Scope of Assessment	4
5	Assessment Methodology	4
6	Technical Findings	5
7	Risk Summary	6
8	Evidence Collected	7
9	Conclusion	7

Executive Summary

This Vulnerability Assessment Report presents the results of a security assessment conducted on OWASP Juice Shop deployed within a controlled cybersecurity laboratory environment. The purpose of the assessment was to identify exposed services, discover accessible resources, evaluate web application security posture, and document potential vulnerabilities without performing exploitation activities.

The assessment was conducted using industry-standard tools including Nmap, Nikto, Docker, and Dirsearch. Network reconnaissance, service enumeration, web vulnerability scanning, and directory discovery activities were performed against the target application.

The assessment identified multiple security observations including missing security headers, publicly accessible application resources, exposed API documentation endpoints, and permissive configuration settings. These findings demonstrate common web application security weaknesses that could increase risk if deployed in a production environment.

The assessment was performed ethically within a personal cybersecurity lab environment and all findings were documented for educational and security awareness purposes.

1. Introduction

Vulnerability assessment is a systematic process used to identify security weaknesses within systems, networks, and applications before they can be exploited by malicious actors. Security analysts perform vulnerability assessments to understand potential risks, improve system security, and recommend remediation strategies.

For this task, OWASP Juice Shop was selected as the assessment target because it is intentionally designed to demonstrate common web application vulnerabilities and security misconfigurations. The assessment focused on information gathering, service identification, vulnerability discovery, and documentation rather than exploitation.

2. Assessment Objectives

The objectives of this assessment were:

- Discover active hosts within the cybersecurity lab environment.
- Identify exposed services and accessible network ports.
- Verify web application accessibility.
- Detect web application security weaknesses.
- Enumerate directories and exposed application resources.
- Document findings using professional reporting practices.
- Recommend remediation strategies for identified issues.

3. Scope of Assessment

In Scope

- OWASP Juice Shop
- Docker-hosted application environment
- Network reconnaissance
- Port scanning
- Service enumeration
- Web vulnerability assessment
- Directory enumeration

Out of Scope

- Exploitation activities
- Denial of Service testing
- Real-world production systems
- Unauthorized systems or networks

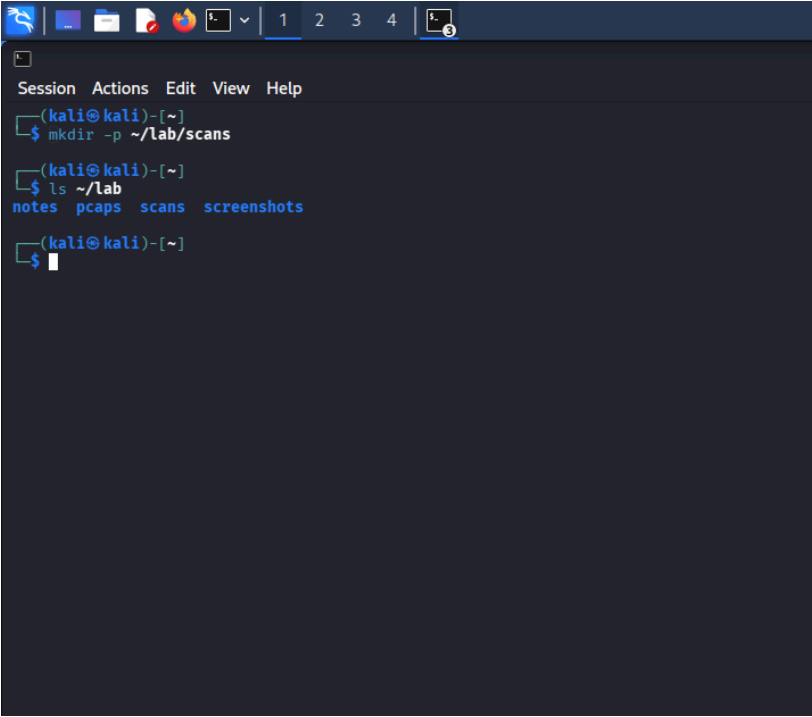
4. Assessment Methodology

The assessment followed a structured vulnerability assessment workflow.

Phase 1 – Environment Preparation

A dedicated project structure was created to organize assessment evidence, scan outputs, and screenshots. Evidence folders were prepared to maintain documentation throughout the assessment process.

Screenshot 1: Scan Directory Created



```
Session Actions Edit View Help
(kali@kali)-[~]
$ mkdir -p ~/lab/scans
(kali@kali)-[~]
$ ls ~/lab
notes  pcaps  scans  screenshots
(kali@kali)-[~]
$
```

Phase 2 – Host Discovery

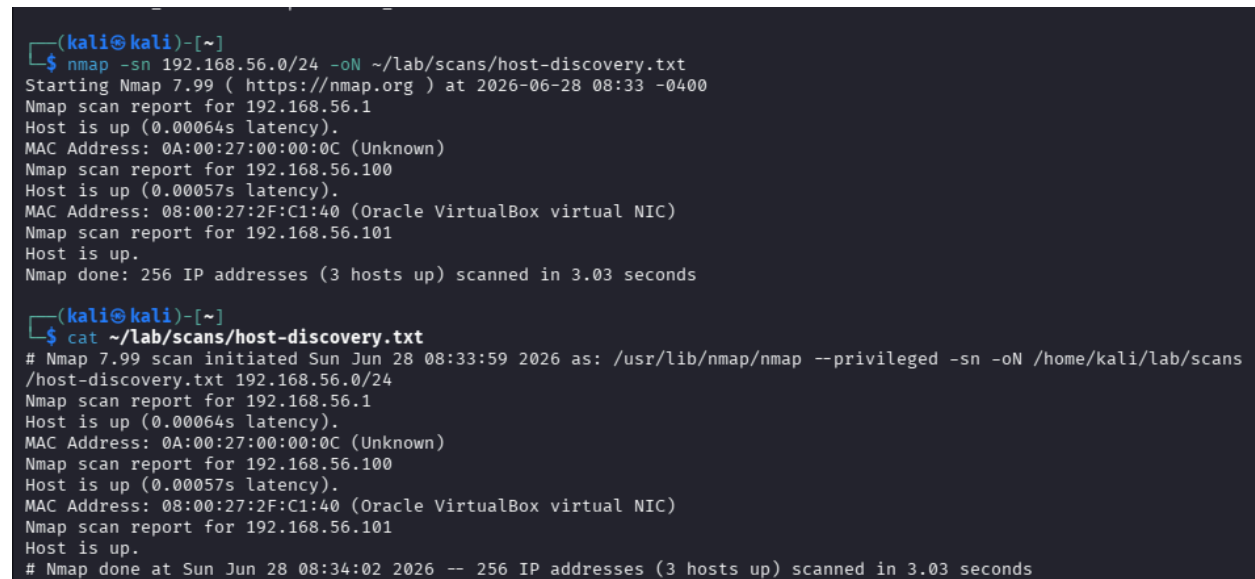
Network reconnaissance was performed using Nmap to identify active systems within the Host-Only network environment.

Tool Used: Nmap

Command: `nmap -sn 192.168.56.0/24`

Result: Multiple active hosts were successfully identified within the laboratory network, confirming target accessibility.

Screenshot 2: Nmap Host Discovery



```
(kali@kali)-[~]
$ nmap -sn 192.168.56.0/24 -oN ~/lab/scans/host-discovery.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 08:33 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00064s latency).
MAC Address: 0A:00:27:00:00:0C (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00057s latency).
MAC Address: 08:00:27:2F:C1:40 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 3.03 seconds

(kali@kali)-[~]
$ cat ~/lab/scans/host-discovery.txt
# Nmap 7.99 scan initiated Sun Jun 28 08:33:59 2026 as: /usr/lib/nmap/nmap --privileged -sn -oN /home/kali/lab/scans
/host-discovery.txt 192.168.56.0/24
Nmap scan report for 192.168.56.1
Host is up (0.00064s latency).
MAC Address: 0A:00:27:00:00:0C (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00057s latency).
MAC Address: 08:00:27:2F:C1:40 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
# Nmap done at Sun Jun 28 08:34:02 2026 -- 256 IP addresses (3 hosts up) scanned in 3.03 seconds
```

Phase 3 – Service Enumeration

Port scanning and service detection activities were performed to identify accessible services running on the target environment.

Tool Used: Nmap

Command: `nmap -sV -p 3000 localhost`

Result: OWASP Juice Shop was identified running on TCP Port 3000. Service enumeration confirmed that the application was accessible and operational.

Screenshot 3: Port and Service Enumeration

```
(kali@kali)-[~]
└─$ nmap -sV 192.168.56.101 -oN ~/lab/scans/full-service-scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 08:48 -0400
Stats: 0:01:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 30.00% done; ETC: 08:51 (0:02:27 remaining)
Stats: 0:01:49 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 52.50% done; ETC: 08:51 (0:01:39 remaining)
Stats: 0:02:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 77.00% done; ETC: 08:51 (0:00:47 remaining)
Stats: 0:03:17 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 95.50% done; ETC: 08:51 (0:00:09 remaining)
Nmap scan report for 192.168.56.101
Host is up.
All 1000 scanned ports on 192.168.56.101 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 207.19 seconds

(kali@kali)-[~]
└─$ cat ~/lab/scans/full-service-scan.txt
# Nmap 7.99 scan initiated Sun Jun 28 08:48:21 2026 as: /usr/lib/nmap/nmap --privileged -sV -oN /home/kali/lab/scans/full-service-scan.txt 192.168.56.101
Nmap scan report for 192.168.56.101
Host is up.
All 1000 scanned ports on 192.168.56.101 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Jun 28 08:51:48 2026 -- 1 IP address (1 host up) scanned in 207.19 seconds
```

Screenshot 4: Juice Shop Service Enumeration

```
(kali@kali)-[~]
$ cat ~/lab/scans/juice-shop-service-scan.txt
# Nmap 7.99 scan initiated Sun Jun 28 09:05:33 2026 as: /usr/lib/nmap/nmap --privileged -sV -p 3000 -oN /home/kali/lab/scans/juice-shop-service-scan.txt localhost
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00014s latency).
Other addresses for localhost (not scanned): ::1

PORT      STATE SERVICE VERSION
3000/tcp open  ppp?

1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3000-TCP:V=7.99%I=7%D=6/28%Time=6A411C29P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,2866,"HTTP/1.1\x20200\x200K\r\nAccess-Control-Allow-Origin:\x
SF:20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEO
SF:RIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/jo
SF:bs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=0
SF:\r\nLast-Modified:\x20Sun,\x2028\x20Jun\x202026\x2013:02:13\x20GMT\r\nE
SF:Tag:\x20W/"26af-19f0e52c772"\r\nContent-Type:\x20text/html;\x20charse
SF:t=UTF-8\r\nContent-Length:\x209903\r\nVary:\x20Accept-Encoding\r\nDate:
SF:\x20Sun,\x2028\x20Jun\x202026\x2013:05:45\x20GMT\r\nConnection:\x20clo
SF:e\r\n\r\n!DOCTYPE\x20HTML\x20PUBLIC\x20"\"<!--\x20\x20\x20Copyright\x20(c)\x202014-2026\x20Bjoern\x
SF:20Kimminich\x20the\x20OWASP\x20Juice\x20Shop\x20contributors.\n\x
SF:20\x20\x20SPDX-License-Identifier:\x20MIT\n\x20\x20-->\n\n<!doctype\x2
SF:0html>\n<html\x20lang=\x20en\x20data-beasties-container>\n<head>\n\x20\
SF:\x20<meta\x20charset=\x20utf-8\x20>\n\x20\x20<title>OWASP\x20Juice\x20Shop</
SF:title>\n\x20\x20<meta\x20name=\x20"description\x20content=\x20"Probably\x20
SF:the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x20app
SF:lication\x20">\n\x20\x20<meta\x20name=\x20"viewport\x20content=\x20"width=devi
SF:ce-width,\x20initial-scale=1\x20">\n\x20\x20<link\x20rel=\x20"preconnect\x20
SF:href=\x20"http" %r(HELP,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnecti
SF:on:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\n
SF:Connection:\x20close\r\n\r\n")%r(HTTPOptions,EA,"HTTP/1.1\x20204\x20No
SF:\x20Content\r\nAccess-Control-Allow-Origin:\x20*\r\nAccess-Control-All
SF:ow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-Contro
SF:l-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Sun,\x2028\x20Jun
SF:\x202026\x2013:05:45\x20GMT\r\nConnection:\x20close\r\n\r\n")%r(RTSPReq
SF:uest,EA,"HTTP/1.1\x20204\x20No\x20Content\r\nAccess-Control-Allow-Orig
SF:in:\x20*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,D
SF:ELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length:\x20
SF:0\r\nDate:\x20Sun,\x2028\x20Jun\x202026\x2013:05:45\x20GMT\r\nConnectio
SF:n:\x20close\r\n\r\n")%r(RPCCheck,2F,"HTTP/1.1\x20400\x20Bad\x20Request
SF:\r\n\r\nConnection:\x20close\r\n\r\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Jun 28 09:05:45 2026 -- 1 IP address (1 host up) scanned in 11.86 seconds
```


Phase 4 – Docker Verification

Docker container status was validated to confirm that the target application was running correctly.

Commands Used: `sudo docker ps -a`, `sudo docker ps`

Result: The OWASP Juice Shop container was successfully started and verified as operational.

Screenshot 5: Docker Container Status

```
(kali@kali)-[~]
└─$ sudo docker ps -a
```

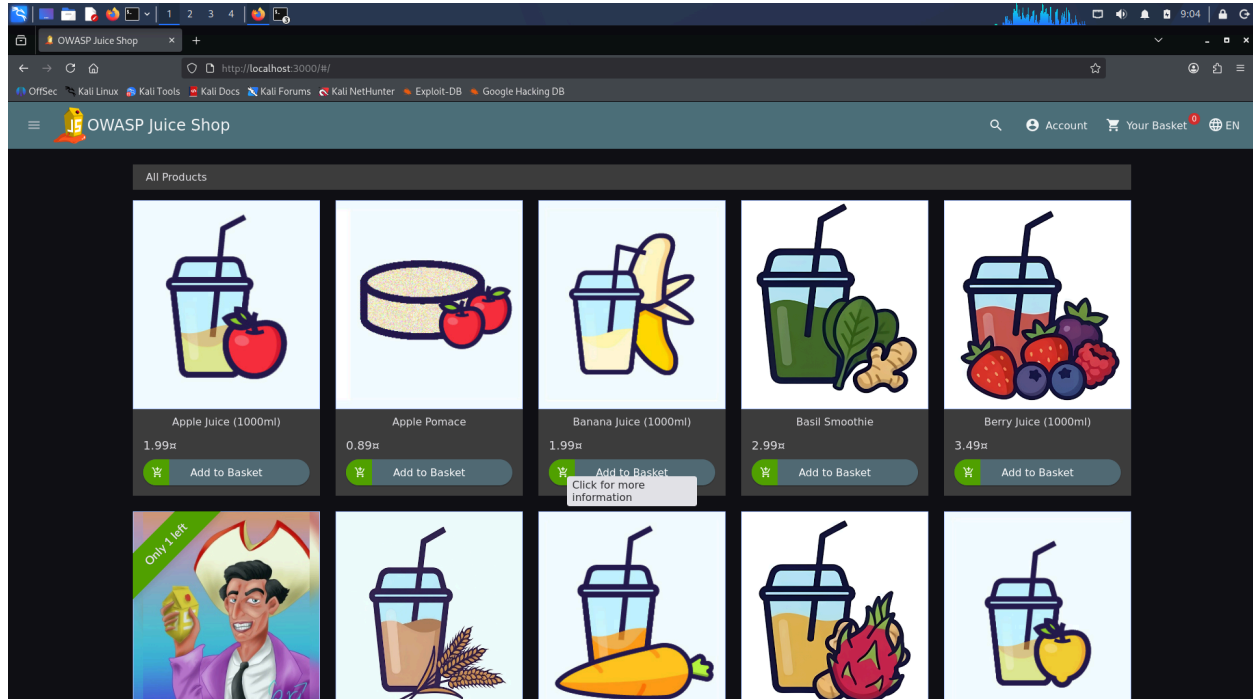
CONTAINER ID	IMAGE	COMMAND	CREATED	STATUS	PORTS	NAM
ES						
bf0eb441a73a	bkimminich/juice-shop	"/nodejs/bin/node /j..."	2 weeks ago	Exited (0) 2 weeks ago		juice

Screenshot 6: Juice Shop Running

```
(kali@kali)-[~]
└─$ sudo docker ps
```

CONTAINER ID	IMAGE	COMMAND	CREATED	STATUS	PORTS	NAM
ES						
bf0eb441a73a	bkimminich/juice-shop	"/nodejs/bin/node /j..."	2 weeks ago	Up 21 seconds	0.0.0.0:3000→3000/tcp, [::]:3000→3000/tcp	juice

Screenshot 7: OWASP Juice Shop Web Application



Phase 5 – Vulnerability Assessment

Web application vulnerability scanning was performed using Nikto.

Tool Used: Nikto

Command: nikto -h http://localhost:3000

Result: Multiple security observations related to application configuration and security headers were identified.

Screenshot 8: Nikto Web Vulnerability Scan

```
(kali@kali)-[~]
$ nikto -Version
Nikto 2.6.0 (LW 2.5)

(kali@kali)-[~]
$ nikto -h http://localhost:3000 -output ~/lab/scans/nikto-scan.txt
- Nikto v2.6.0

+ Target IP:      127.0.0.1
+ Target Hostname: localhost
+ Target Port:    3000
+ Platform:       Unknown
+ Start Time:     2026-06-28 09:09:31 (GMT-4)

+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
```

Phase 6 – Directory Enumeration

Directory and resource discovery was conducted using Dirsearch.

Tool Used: Dirsearch

Command: dirsearch -u http://localhost:3000

Result: Multiple resources, API endpoints, and application documentation paths were discovered.

Screenshot 9: Directory Enumeration

```
(kali@kali)~$ dirsearch -u http://localhost:3000 -o ~/lab/scans/dirsearch-scan.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/lab/scans/dirsearch-scan.txt
Target: http://localhost:3000/

[09:14:14] Starting:
[09:14:39] 200 - 475B - /.well-known/security.txt
[09:15:31] 500 - 3KB - /api
[09:15:32] 301 - 158B - /api-docs → /api-docs/
[09:15:33] 500 - 3KB - /api-doc
[09:15:33] 500 - 3KB - /api/2/explore/
[09:15:33] 500 - 3KB - /api.php
[09:15:33] 500 - 3KB - /api/
[09:15:33] 500 - 3KB - /api.log
[09:15:33] 500 - 3KB - /api.py
[09:15:33] 500 - 3KB - /api/_swagger_/
[09:15:33] 500 - 3KB - /api/2/issue/createmeta
[09:15:33] 500 - 3KB - /api/api
[09:15:34] 500 - 3KB - /api/_swagger_/
[09:15:34] 500 - 3KB - /api/api-docs
[09:15:34] 500 - 3KB - /api/apidocs/swagger.json
[09:15:34] 500 - 3KB - /api/apidocs
[09:15:34] 500 - 3KB - /api/batch
[09:15:34] 500 - 3KB - /api/application.wadl
[09:15:34] 500 - 3KB - /api/config
[09:15:34] 500 - 3KB - /api/cask/graphql
[09:15:35] 500 - 3KB - /api/docs
[09:15:35] 500 - 3KB - /api/swagger.json
[09:15:35] 500 - 3KB - /api/swagger-ui.html
[09:15:35] 500 - 3KB - /api/profile
[09:15:35] 500 - 3KB - /api/docs/
[09:15:35] 500 - 3KB - /api/error_log
[09:15:35] 500 - 3KB - /api/login.json
[09:15:35] 500 - 3KB - /api/jsomes/invoke
[09:15:35] 500 - 3KB - /api/jsomes
[09:15:35] 500 - 3KB - /api/package_search/v4/documentation
[09:15:35] 500 - 3KB - /api/index.html
[09:15:35] 500 - 3KB - /api/spec/swagger.json
[09:15:36] 500 - 3KB - /api/proxy
[09:15:36] 500 - 3KB - /api/swagger.yml
[09:15:36] 500 - 3KB - /api/swagger
[09:15:36] 500 - 3KB - /api/swagger.yaml
[09:15:36] 500 - 3KB - /api/snapshots
```

5. Technical Findings

Finding 1 – Missing Strict-Transport-Security Header

Severity: Medium

Description: The application does not implement the Strict-Transport-Security (HSTS) header. Without HSTS, browsers may communicate using insecure HTTP connections, increasing the risk of downgrade attacks.

Impact: Potential exposure of communication channels to interception attacks.

Recommendation: Implement HSTS with appropriate configuration and enforce HTTPS communication.

Finding 2 – Missing Content-Security-Policy Header

Severity: Medium

Description: The application does not define a Content Security Policy (CSP).

Impact: Increased exposure to client-side attacks such as Cross-Site Scripting (XSS).

Recommendation: Implement a restrictive Content Security Policy to control resource loading and script execution.

Finding 3 – Missing Referrer-Policy Header

Severity: Low

Description: The Referrer-Policy header was not configured.

Impact: Sensitive URL information may be disclosed to external resources.

Recommendation: Configure an appropriate Referrer-Policy header.

Finding 4 – Missing Permissions-Policy Header

Severity: Low

Description: Browser feature restrictions were not explicitly configured.

Impact: Unnecessary browser capabilities may remain available.

Recommendation: Implement a Permissions-Policy header to restrict browser functionality.

Finding 5 – robots.txt Accessible

Severity: Low

Description: Nikto identified an accessible robots.txt file.

Impact: May reveal application paths or information useful during reconnaissance.

Recommendation: Review robots.txt content and avoid exposing sensitive paths.

Finding 6 – Access-Control-Allow-Origin Wildcard Configuration

Severity: Medium

Description: The application permits unrestricted cross-origin access.

Impact: Potential misuse by unauthorized external domains.

Recommendation: Restrict CORS access to trusted origins only.

Finding 7 – Exposed API Documentation and Endpoints

Severity: Medium

Description: Directory enumeration identified: /api, /api-docs, /.well-known/security.txt

Impact: Exposed endpoints may provide information useful for attackers during reconnaissance.

Recommendation: Restrict access to sensitive documentation and review publicly accessible endpoints.

6. Risk Summary

Finding	Severity
Missing HSTS Header	Medium ▾
Missing CSP Header	Medium ▾
Missing Referrer Policy	Low ▾

Finding	Severity
Missing Permissions Policy	Low ▾
Accessible robots.txt	Low ▾
Wildcard CORS Configuration	Medium ▾
Exposed API Documentation	Medium ▾

7. Conclusion

The vulnerability assessment successfully identified exposed services, publicly accessible resources, and several web application security observations within the OWASP Juice Shop environment. Through host discovery, service enumeration, vulnerability scanning, and directory enumeration activities, practical understanding of cybersecurity assessment methodologies was achieved.

The task provided valuable hands-on experience with professional security tools including Nmap, Nikto, Docker, and Dirsearch. It also strengthened skills related to reconnaissance, evidence collection, documentation, and cybersecurity reporting. The findings and remediation recommendations generated during this assessment can help improve overall security posture and support future penetration testing activities